

Cybersecurity Basics 1 Project, Rubric 2

Develop a Comprehensive Security Policy

Submit a security policy document outlining at least 3 key security Rules/Guidelines, an incident response plan detailing steps to be taken in case of a security breach and a section explaining how these policies and procedures maintain the CIA Triad

Comprehensive Information Security Policy

This document establishes the official security rules, breach response protocols, and strategic alignment required to protect organizational assets. Compliance with this policy is mandatory for all employees, contractors, and third-party partners.

Key Security Guidelines & Rules

1. Access Control & Multi-Factor Authentication (MFA)

- **Rule:** Access to systems and data is granted on the **Principle of Least Privilege** (users receive only the access necessary to perform their role).
- **Guideline:** Multi-Factor Authentication (MFA) is strictly required for all corporate accounts, VPNs, and cloud application access. Passwords must be at least 14 characters long and utilize a combination of letters, numbers, and special characters.

2. Data Encryption & Handling

- **Rule:** All sensitive, confidential, and proprietary data must be encrypted **at rest** (using AES-256 encryption) and **in transit** (using TLS 1.3 or higher).
- **Guideline:** Employees are prohibited from storing organizational data on unapproved personal devices (BYOD) or transferring sensitive files via unencrypted external media (e.g., standard USB drives) or unsecured personal file-sharing services.

3. Patch Management & Endpoint Protection

- **Rule:** All corporate-managed devices must run organizationally approved Endpoint Detection and Response (EDR) software and maintain continuous connectivity to patch management systems.
- **Guideline:** Critical security patches issued by vendor advisories must be tested and applied within 72 hours of release. High-risk vulnerability patches must be deployed within 14 days.

Incident Response Plan (IRP)

In the event of a suspected or confirmed security breach, the organization follows a structured six-phase incident response process:

[1. Preparation] → [2. Identification] → [3. Containment] → [4. Eradication] → [5. Recovery] → [6. Lessons Learned]

- **Phase 1: Preparation:** Maintain and update security tools, train the Incident Response Team (IRT), conduct regular threat hunting, and perform offline data backups.
- **Phase 2: Identification:** Detect and analyze security anomalies using SIEM alerts, automated EDR signals, or user reports. The IRT assesses the scope, severity, and impacted systems to officially declare an incident.
- **Phase 3: Containment:**
 - *Short-Term:* Isolate affected systems from the network (disconnect physical cables/Wi-Fi or apply network segmentation) to block lateral movement.
 - *Long-Term:* Apply temporary firewall blocks, disable compromised user credentials, and capture volatile memory dumps for forensic analysis.
- **Phase 4: Eradication:** Locate and eliminate the root cause of the breach. This includes removing malware, deleting unauthorized registry entries/backdoors, revoking compromised access keys, and patching the initial entry vulnerability.
- **Phase 5: Recovery:** Restore systems to operational status using clean, verified backups. Reconnect devices to the production network, force

account password resets, and run high-frequency monitoring on impacted network segments to verify stability.

- **Phase 6: Lessons Learned:** Within 14 days of incident resolution, conduct a post-incident review to document the root cause, evaluate response efficiency, identify policy gaps, and update controls to prevent recurrence.

Alignment with the CIA Triad

This security policy directly supports the core pillars of the **CIA Triad** (Confidentiality, Integrity, and Availability):

CIA Pillar	Policy & Response Alignment	Operational Impact
Confidentiality	• Least privilege access policies • MFA enforcement • Full-disk and in-transit encryption	Ensures that sensitive system data is accessible only to authorized personnel and remains unreadable to unauthorized external threat actors or malicious insiders.

Integrity	• EDR monitoring and patch management • Forensic analysis during incident response • Containment and eradication protocols	Prevents unauthorized modification, tampering, or destruction of organizational data and system configurations by malware or attackers.
Availability	• Structured system recovery from clean offline backups • Rapid network isolation to limit breach blast radius	Minimizes operational downtime during a security breach and ensures business systems and data remain reliably accessible to authorized users when needed.

	• Post-incident review and system hardening	
--	---	--